Microsoft Purview CMMC Compliance Program

Implementation Solution Guide

Version 1.0.0 · 2026-07-07

Contents

Executive Summary — Microsoft Purview CMMC Compliance Program 5

What you get . . . 5

What this delivers . . . 5

The standard deployment model . . . 5

What this does not do . . . 5

Outcome . . . 6

1. Solution Overview — Microsoft Purview CMMC Compliance Program 6

What this solution is . . . 6

Why this matters . . . 6

How it works . . . 7

The building blocks (what Compliance Manager gives you for CMMC) . . . 8

The role-separation model (least privilege) . . . 8

Limitations (be honest with buyers) . . . 8

Naming convention (used in every doc and script) . . . 9

The standard deployment model . . . 10

2. Requirements Guide — Microsoft Purview CMMC Compliance Program 10

2.1 Licensing — Compliance Manager and the CMMC / NIST 800-171 premium template . . . 10

2.2 Cloud environment for CUI (Commercial vs GCC / GCC High) . . . 11

2.3 Compliance Manager role groups populated with least-privilege separation . . . 11

2.4 Named compliance, security & legal owners (applicability + adequacy + certification) . . . 11

2.5 CUI boundary / scope and the SSP defined . . . 11

2.6 Improvement-action owners and evidence sources identified . . . 12

2.7 Automatic-testing decision and the underlying technical signals . . . 12

2.8 Security & Compliance PowerShell + Microsoft Graph toolchain . . . 12

2.9 A pilot assessment and change control . . . 13

Checklist . . . 13

Global Requirements — Microsoft Purview Solutions 13

1. Microsoft 365 tenant with the required Purview/compliance licensing . . . 14

2. Purview roles (least-privilege) and portal access . . . 14

3. Security & Compliance PowerShell + Graph toolchain . . . 14

4. Data sources & scope in scope . . . 15

5. Compliance, records, privacy & legal stakeholders . . . 15

6. A pilot scope and change control . . . 15

3. Implementation Guide — Microsoft Purview CMMC Compliance Program 16

Step 1 — Baseline the posture and capture role/licensing readiness (Assess) . . . 16

Step 2 — Assign roles with least-privilege separation (Configure — guardrails) . . . 17
Step 3 — Design the assessment, CUI boundary, and owners (Design) . . . 17
Step 4 — Create the pilot assessment (Configure — pilot-first) . . . 17
Step 5 — Build the action plan, control map, and evidence register (Configure) . . . 18
Step 6 — Enable automatic testing where it applies (Configure) . . . 18
Step 7 — Validate the evidence behind the actions (Pilot → Validate) . . . 19
Step 8 — Expand to the full CMMC set and run the cadence (Expand) . . . 19
5. Testing Guide — Microsoft Purview CMMC Compliance Program 20
Test 1 — Role separation is in place (the access guardrail) . . . 20
Test 2 — Licensing/cloud supports the CMMC template . . . 20
Test 3 — The pilot assessment exists and is scored . . . 20
Test 4 — Every pilot action is mapped and has an owner, date, status, and evidence source . . . 21
Test 5 — Automatic testing reflects the real technical state (true evidence) . . . 21
Test 6 — A not-yet-implemented control scores as such (no false pass) . . . 21
Test 7 — Manual evidence is attached and defensible . . . 21
Test 8 — Control mapping / shared controls behave as expected . . . 21
Test 9 — Posture report is accurate and complete . . . 21
Test 10 — Safe automation defaults . . . 22
6. Troubleshooting Guide — Microsoft Purview CMMC Compliance Program 22
A. The CMMC / NIST 800-171 template is not available to create . . . 22
B. Compliance Manager role groups missing or misnamed . . . 22
C. Separation-of-duty flag (admin is also a contributor) . . . 23
D. Automatic testing not updating an action's status . . . 23
E. Score looks too high or too low (false pass / false gap) . . . 23
F. `CMMC-Validation.ps1` reports a gap you believe is covered . . . 23
G. `CMMC-Configuration.ps1` won't write the artifacts . . . 24
H. GCC / GCC High connection issues . . . 24
I. Diagnostics quick reference . . . 24
J. What this guide never resolves (by design) . . . 24
K. When to escalate . . . 24
7. Best Practices — Microsoft Purview CMMC Compliance Program 25
8. Deliverables Summary — Microsoft Purview CMMC Compliance Program 26
Documentation . . . 26
PowerShell scripts . . . 26
What the buyer receives . . . 27
Outcome . . . 27

Appendix A — PowerShell Scripts 28

Executive Summary — Microsoft Purview CMMC Compliance Program

White-label · Purview Solutions

For organizations in the Defense Industrial Base, **CMMC** is no longer optional: handling Controlled Unclassified Information (CUI) means implementing — and **evidencing** — the **110 security requirements of NIST SP 800-171** that underpin **CMMC Level 2**, and eventually proving it to a **C3PAO** assessor. The common failure is not a lack of controls; it is a lack of a **measured, owned, evidenced record** of them. "Are we compliant?" gets a shrug instead of a number, and the gaps surface during the assessment rather than before it.

This is a complete, deploy-it-in-order package for standing up a **Purview-backed CMMC compliance program** using **Microsoft Purview Compliance Manager**. It uses the **CMMC Level 2 / NIST SP 800-171 assessment template** to turn CMMC into a **measured posture**, maps each requirement to the control and improvement action that satisfies it, assigns owners, attaches evidence, and validates the technical evidence from your Microsoft 365 configuration — piloted on a single assessment first, validated, then expanded. It is written for an administrator with no prior Compliance Manager experience and uses only the Microsoft Purview portal, Security & Compliance PowerShell, and Microsoft Graph.

What you get

- A plain-language Solution Overview of Compliance Manager, the CMMC/NIST 800-171 template, control

mapping, evidence, and the role-separation model — and how they work together.

- A Requirements Guide with verify / implement-if-missing for every prerequisite, including licensing,

cloud (Commercial vs GCC/GCC High), roles, and the CUI boundary/SSP.

- An Implementation Guide of precise, ordered steps in the Purview portal and PowerShell/Graph.
- Five PowerShell scripts: readiness/role discovery, technical-signal validation, a posture report, a

safe (`-WhatIf`) action-plan/control-map/evidence builder, and a least-privilege role-scope tool.

- Testing and Troubleshooting guides for a confident rollout.

What this delivers

A named, reusable program — a CMMC Level 2 / NIST 800-171 assessment, an owned improvement-action plan, a requirement-to-action **control map**, an evidence register, and least-privilege role separation — deployed on the assess-design-configure-pilot model with technical remediation piloted in simulation/test, and a maintained posture report.

The standard deployment model

Assess → Design → Configure → Pilot (simulate/test) → Validate → Expand.

What this does not do

This program **measures and evidences**; it does **not** issue a CMMC certification, produce a formal assessment determination, or compute your **SPRS** score. **CMMC applicability, the target level, evidence adequacy, scoring, and certification are deferred to the C3PAO and to your compliance, security, and legal functions.** The high-impact technical changes an action recommends are separate, piloted changes owned by their own solution.

Outcome

A defensible, evidenced CMMC program in Microsoft Purview — requirements mapped to configured controls, technical evidence validated, and a maintained posture proven on a pilot before you scale toward the C3PAO assessment.

1. Solution Overview — Microsoft Purview CMMC Compliance Program

What this solution is

The **Cybersecurity Maturity Model Certification (CMMC)** program requires organizations in the U.S. Defense Industrial Base that handle **Controlled Unclassified Information (CUI)** to implement — and **evidence** — a defined set of security controls. **CMMC Level 2** aligns to the **110 security requirements of NIST SP 800-171**, organized into **14 control families/domains** (Access Control, Audit & Accountability, Configuration Management, Identification & Authentication, and so on).

This solution stands up a **Purview-backed CMMC compliance program** using **Microsoft Purview Compliance Manager**: it uses the **CMMC Level 2** (and/or **NIST SP 800-171**) **assessment template** to turn CMMC obligations into a **measured, points-based posture**; it maps each requirement to the **control** and the **improvement action** that satisfies it, assigns an **owner**, and attaches **evidence** (documentation, test results, dates); and it validates the **technical evidence** behind the actions from your Microsoft 365 configuration. The result is a **defensible, evidenced CMMC control record** — configured, piloted on a single assessment first, validated, then expanded — using only the **Microsoft Purview portal**, **Security & Compliance PowerShell** (`Connect-IPPSSession`), and **Microsoft Graph**.

> ***What this does — and does not — do.*** *This solution delivers the **program**: control mapping, configured controls, the ownership/evidence discipline, and the score. It does **not** issue a CMMC certification, produce a formal **assessment determination**, or replace the **C3PAO** (CMMC Third-Party Assessment Organization) assessment. **C3PAO assessment and certification determinations are deferred to the assessor and to your compliance/security governance.** Compliance Manager *measures* your posture; the *technical* changes an improvement action recommends (enabling audit, DLP, MFA/Conditional Access, retention, labels, encryption) are made in those features and, because several are **high-impact**, are **piloted in simulation/test first** under their own change control.*

Why this matters

- **"Are we CMMC-ready?" needs a number, not a guess.** Without a control-by-control assessment,

CMMC readiness is unknowable. Compliance Manager makes it a **measured posture** backed by evidence, so gaps against the 110 NIST 800-171 requirements are visible, owned, and tracked — not

discovered by a C3PAO.

• **Evidence is the deliverable the assessor wants.** A CMMC posture is only defensible if each

requirement carries **who owns it, its implementation status, its test status/date, and the proof**. This solution centralizes that record (`CMMC Evidence – Register`) so producing it is a routine, not a scramble.

• **Control mapping avoids duplicated effort.** One well-implemented control (say, unified audit

logging, which satisfies the **Audit & Accountability (AU)** family) can also map to your NIST 800-53, ISO 27001, or internal baseline. Compliance Manager's **shared/control mapping** shows that leverage so you fix once and score in several frameworks.

• **The determination is not a technical call.** *Whether* your evidence satisfies a CMMC requirement,

your **NIST 800-171 DoD Assessment Methodology** score, your **SPRS** submission, and your certification level are **assessor/compliance/legal determinations**. This solution provides the configuration method and the evidence; it does not score you for the DoD or sign off on adequacy.

How it works

1. **Baseline the posture (Assess).** Capture the current **Compliance Score**, the Compliance Manager

role/licensing readiness, and the state of the technical signals that back CMMC controls (`CMMC Roles – Separation Evidence`, `CMMC-Discovery.ps1`).

1. **Design the assessment and scope (Design).** With compliance/security stakeholders, confirm the

CMMC Level 2 (and/or **NIST SP 800-171**) assessment template is licensed and available, agree the **CUI boundary/enclave** in scope, and record which requirements are in- or out-of-scope (`CMMC Scope – Record`). **Which requirements apply and the certification level sought are the stakeholders' call.**

1. **Populate roles with separation (Configure — guardrails).** Assign the Compliance Manager role

groups least-privilege so **administrators** are separated from action **contributors** and read-only **readers/auditors** — the auditable access record.

1. **Create the assessment and the action plan (Configure).** Create `CMMC Assessment – NIST 800-171 –

Pilot from the template, then build the **improvement-action plan** (CMMC Action Plan – Pilot): each action assigned an **owner**, a **target date**, an **implementation status**, and a **test status**, with **evidence** attached, indexed to its NIST 800-171 requirement (CMMC Control Map – NIST 800-171`).

1. **Turn on automatic testing where it applies (Configure).** Compliance Manager can **automatically

test** eligible improvement actions from your Microsoft 365 configuration signals; enable it so technical actions update status without manual re-checks (`CMMC Automatic Testing – Setting`). Availability is plan/action-dependent — verify.

1. **Validate the evidence (Pilot → Validate).** Confirm the **technical state** behind the actions

(audit enabled, DLP/retention/labels present, Conditional Access/MFA configured) matches what the assessment claims, attach evidence, and set test status/date — piloting any *technical* remediation in simulation/test first (`CMMC-Validation.ps1`).

1. **Report and expand (Validate → Expand).** Roll up the posture, evidence register, and role separation (`CMMC Score Posture – Report`); then complete the remaining CMMC domains/assessments and stand up the **maintenance cadence** (re-test, re-evidence, review owners, watch for template/regulation updates ahead of the C3PAO assessment).

The building blocks (what Compliance Manager gives you for CMMC)

• **Assessment** — the **CMMC Level 2** / **NIST SP 800-171** template's controls as a scored assessment. **Verify the exact template name and availability in your tenant** — template naming and the CMMC model evolve; do not assume.

• **Improvement actions** — the recommended steps that raise the score, each with **points**, **implementation status** (Not implemented / Implemented / Alternative / Planned / Out of scope), **test status**, an **owner**, and **evidence**. Actions are **customer-managed** (yours) or **Microsoft-managed** (Microsoft's shared responsibility for the platform).

• **Controls & control mapping** — each NIST 800-171 requirement is a control; the **same** control can appear across many assessments, so one fix scores in several frameworks (shared/control mapping).

• **Evidence & the score** — points accrue as actions are implemented and tested; **evidence** attached to each action is the defensible audit trail. The **authoritative score and export** live in the Compliance Manager area of the portal.

The role-separation model (least privilege)

Role group	Who	Can (typical)
Compliance Manager Administrators	Program owners / IT config	Read and edit all Compliance Manager data; manage settings, templates, and role assignment
Compliance Manager Assessors	Assessment leads	Read data, **create assessments**, implement improvement actions, and edit **test** status
Compliance Manager Contributors	Action owners	Read data, create assessments, and **edit improvement actions** (not test status)
Compliance Manager Readers	Oversight / assessors / auditors	**Read-only** access to Compliance Manager data

> *Global Administrator, Compliance Administrator, and Compliance Data Administrator also have access. **Verify the exact role/role-group names and rights in your tenant** — Purview role naming and Compliance Manager permissions evolve. Least privilege is the point: assessors/contributors should not need administrator rights, and readers/auditors get read-only.*

Limitations (be honest with buyers)

- **It measures, it doesn't certify.** Compliance Manager scores and recommends; it does **not** change

your tenant, produce a CMMC certification, or replace the **C3PAO assessment**. Certification and the formal assessment determination are the assessor's; acting on an improvement action is a **separate**, piloted configuration change owned by that feature's solution.

- **Premium/CMMC templates are licensing-gated.** The **Data Protection Baseline** is included; the

CMMC Level 2 / NIST SP 800-171 and other **premium assessment templates** require **Microsoft 365 E5 / E5 Compliance** or the **Compliance Manager Premium Assessment Add-On**, and the **number** of premium assessments depends on your licensing/seat count. **Verify entitlement — do not assume a template is available.**

- **CUI often means a sovereign cloud.** Many CMMC-regulated organizations must run CUI workloads in

GCC High (or GCC). Feature availability, template naming, and portal paths **differ** in government clouds — **verify against your tenant/cloud**.

- **Portal-driven.** Assessments, improvement actions, evidence upload, and the authoritative score are

managed in the **Purview portal**. Compliance Manager does **not** expose a broad public PowerShell/Graph API to create assessments or set action status programmatically; the provided scripts assess **readiness, roles, and the technical evidence** behind actions and structure the action/evidence/control-map plan — they do not replace the portal.

- **Automatic testing is partial.** Only **eligible** actions auto-test from Microsoft 365 signals;

others require manual implementation/test and uploaded evidence. Availability is plan/action-dependent — verify.

- **Applicability, adequacy, and the SPRS score are not technical.** *Which* requirements apply,

whether evidence satisfies them, your **NIST 800-171 DoD Assessment Methodology** score, and the **SPRS** submission are **compliance/security/legal/assessor** determinations, not outputs of this tool.

- **No secrets in automation.** The provided scripts use interactive modern-auth sign-in; they never

embed credentials.

Naming convention (used in every doc and script)

Every artifact this solution creates or tracks is named `<Purpose> – <Scope> – <Stage>` and reused verbatim across the docs, scripts, and portal:

Artifact	Name
Assessment (pilot)	`CMMC Assessment – NIST 800-171 – Pilot`
Assessment (production)	`CMMC Assessment – Level 2 – Production`
Improvement-action plan (pilot)	`CMMC Action Plan – Pilot`
Control map (requirement → action → evidence)	`CMMC Control Map – NIST 800-171`
Evidence register	`CMMC Evidence – Register`
Automatic-testing setting	`CMMC Automatic Testing – Setting`

Artifact	Name
Score posture report	`CMMC Score Posture – Report`
Role-separation evidence snapshot	`CMMC Roles – Separation Evidence`
Scope / CUI-boundary record	`CMMC Scope – Record`

The standard deployment model

> *Baseline the posture → design the in-scope CMMC/NIST 800-171 assessment, CUI boundary, and owners → configure roles (separation), create the assessment, build the action plan + control map, enable automatic testing → validate the evidence behind the actions (piloting any technical remediation in simulation/test) → report the posture → expand to the full domain set and run the maintenance cadence toward the C3PAO assessment. Pattern:* ***Assess → Design → Configure → Pilot (simulate/test) → Validate → Expand*** *— CMMC certification, assessment determinations, and SPRS scoring deferred to the C3PAO and to compliance/security/legal at every step.*

2. Requirements Guide — Microsoft Purview CMMC Compliance Program

Verify **every** requirement before configuring. Each entry: **Description · Why · Verify · Implement-if-missing.** Category-wide prerequisites (tenant licensing, Purview roles, the PowerShell/Graph toolchain, in-scope data sources, compliance/privacy/legal stakeholders, and a pilot scope with change control) are in `global-requirements-purview.md` — this guide adds the CMMC-specific detail. **Licensing, template availability, cloud (Commercial vs GCC/GCC High), and portal paths are plan-/cloud-dependent and the portal evolves — verify each against your own tenant.**

2.1 Licensing — Compliance Manager and the CMMC / NIST 800-171 premium template

Description: Compliance Manager and the **Data Protection Baseline** assessment are available to all Microsoft 365 / Office 365 commercial subscriptions. The **CMMC Level 2** and **NIST SP 800-171 premium assessment templates** (and custom templates) require **Microsoft 365 E5 / E5 Compliance** or the **Compliance Manager Premium Assessment Add-On**; the **number** of premium assessments you can create is a function of your licensing / seat entitlement. **Why:** The baseline is included, but the CMMC/NIST 800-171 template is entitlement-gated — the single most common blocker. A template you plan to assess against may not be available on your plan. **Verify:** Microsoft 365 admin center → `Billing` → `Licenses` for the E5 / E5 Compliance / add-on entitlement; in the Purview portal → **Compliance Manager** → **Assessment templates**, confirm the **CMMC Level 2** and/or **NIST SP 800-171** template shows as **available to create**. `CMMC-Discovery.ps1` reports the licensing SKUs it can read via Graph. **Confirm exact entitlement and the exact template name with Microsoft licensing — do not assume.** **Implement:** Assign/purchase the required E5 / E5 Compliance / Premium Assessment Add-On before relying on the CMMC/NIST template.

2.2 Cloud environment for CUI (Commercial vs GCC / GCC High)

Description: The Microsoft 365 **cloud** the CUI workloads live in — **Commercial**, **GCC**, or **GCC High**. Many CMMC Level 2 / CUI obligations (including ITAR-controlled data) require **GCC High**; DFARS 7012 requires the cloud service to meet **FedRAMP Moderate (or equivalent)** and support the required incident-reporting and forensic obligations. **Why:** Feature availability, assessment-template naming, portal paths, and even which cmdlets work **differ** between Commercial and government clouds. Building the program in the wrong cloud is a rework and, for regulated CUI, a compliance failure. **Verify:** Confirm the tenant's cloud with your governance owners and Microsoft; check that the CMMC template and Compliance Manager features you need are present **in that cloud**. **Which cloud CUI must reside in is a compliance/contractual determination. Implement:** Ensure CUI workloads are in the contractually required cloud before building the program; if a migration is needed, that is a separate, governed project.

2.3 Compliance Manager role groups populated with least-privilege separation

Description: The Compliance-Manager-specific role groups — **Compliance Manager Administrators**, **Compliance Manager Assessors**, **Compliance Manager Contributors**, and **Compliance Manager Readers** — populated so administrators are separated from action **contributors** and from read-only **readers/auditors** (including any external C3PAO reader access). (Global Administrator, Compliance Administrator, and Compliance Data Administrator also grant access.) **Why:** Least-privilege separation is itself a CMMC control (Access Control / least privilege) and the auditable access record: contributors update actions and evidence without administrator rights, and oversight/assessors get read-only. The evidence you produce is only defensible if access to it was governed. **Verify:** Purview portal → `Settings` → `Roles & scopes` → `Permissions` (or, via `Connect-IPPSSession`, `Get-RoleGroupMember 'Compliance Manager Contributors'` etc.) shows the intended, separated membership. `CMMC-Discovery.ps1` prints each group's membership as the `CMMC Roles – Separation Evidence` snapshot and flags administrators who are also contributors. **Verify the exact role-group names in your tenant — Purview role naming evolves. Implement:** Assign membership under change control with `CMMC-Set-Scope.ps1` (`-WhatIf` first, then `-Commit`); grant the **minimum** role each person needs and keep readers/auditors read-only.

2.4 Named compliance, security & legal owners (applicability + adequacy + certification)

Description: Named owners in **compliance, security, and legal** who decide **which CMMC level** is sought, **which NIST 800-171 requirements** are in or out of scope, whether **System Security Plan (SSP)** and **Plan of Action & Milestones (POA&M)** evidence satisfies the obligation, and who owns the relationship with the **C3PAO** — plus a **business owner** for each in-scope domain. **Why:** CMMC applicability, the level sought, evidence adequacy, the SPRS score, and the certification determination are **not** technical determinations. The score and evidence are inputs to a compliance decision; the decision itself belongs to these functions and, ultimately, the assessor. **Verify:** The target level, the in-/out-of-scope requirements, the SSP/POA&M owners, and the named approvers are recorded (`CMMC Scope – Record`). **Implement:** Engage the governance functions, capture the target level and scope decisions, and assign an owner per domain before building the action plan.

2.5 CUI boundary / scope and the SSP defined

Description: A defined **CUI boundary** (the systems, enclave, users, and data that store, process, or transmit CUI) and a **System Security Plan (SSP)** that describes how each NIST 800-171 requirement is met — the authoritative scope the assessment measures against. **Why:** CMMC scores against a boundary; without an agreed boundary and SSP the assessment is measuring the wrong estate, and the C3PAO will scope to the boundary anyway. **Verify:** A documented CUI boundary/enclave and a current SSP exist, agreed with the governance owners (`CMMC Scope – Record`). **Implement:** Define and document the CUI boundary and SSP with security/compliance before creating the assessment. **Boundary definition is a compliance/security determination.**

2.6 Improvement-action owners and evidence sources identified

Description: For the pilot assessment, the **owner** of each improvement action, the **target date**, and where the **evidence** comes from — including which actions are candidates for **automatic testing** (auto-updated from Microsoft 365 signals) versus **manual** evidence upload (policies, procedures, screenshots, SSP/POA&M references). **Why:** A CMMC posture with no owners and no evidence is not defensible to a C3PAO. Ownership and evidence source turn recommendations into a trackable, auditable plan (`CMMC Action Plan – Pilot`, `CMMC Evidence – Register`, `CMMC Control Map – NIST 800-171`). **Verify:** Each pilot action has an owner, a target date, and a named evidence source; automatic-vs- manual actions are identified. **Implement:** Build the action plan and control map with `CMMC-Configuration.ps1` (`-WhatIf` first) from the owner-provided list; capture the evidence source per action.

2.7 Automatic-testing decision and the underlying technical signals

Description: A decision on whether to enable **automatic testing** of eligible improvement actions (continuous monitoring reads your Microsoft 365 configuration to update an action's status), and awareness that automatic testing depends on the **underlying technical controls** — e.g. **unified audit logging** (AU family), **Conditional Access / MFA** (AC/IA families), **DLP / retention / sensitivity-label / encryption** policies (MP/SC families) — actually being present. **Why:** Automatic testing keeps technical actions current without manual re-checks — but only for **eligible** actions, and only when the underlying signal exists. Knowing which is which prevents a false sense of coverage against the 110 requirements. **Verify:** Purview portal → **Compliance Manager** → **Settings** for the automatic-testing option (`CMMC Automatic Testing – Setting`); `CMMC-Validation.ps1` reports the state of the common technical signals (audit, DLP, retention, labels, Conditional Access/MFA) that back automatable NIST 800-171 actions. **Implement:** Enable automatic testing where your governance owners agree; for actions it can't auto-test, plan manual evidence.

2.8 Security & Compliance PowerShell + Microsoft Graph toolchain

Description: A workstation with the **ExchangeOnlineManagement** module (providing `Connect-IPPSSession` for role-group and evidence cmdlets) and **Microsoft Graph PowerShell** (for licensing and Conditional Access/MFA evidence), used with a modern-auth / MFA-capable admin holding the appropriate Compliance Manager and read roles. In **GCC High**, use the environment-specific endpoints (`Connect-IPPSSession -ConnectionUri`/`Connect-MgGraph -Environment`). **Why:** The five provided scripts assess readiness, roles, and technical evidence through Security & Compliance PowerShell and Graph. Compliance Manager itself is **portal-managed** — the scripts support it, they do not create assessments. **Verify:** `Connect-IPPSSession` and `Connect-MgGraph` succeed;

`Get-RoleGroup` returns the Compliance Manager groups. `CMMC-Discovery.ps1` performs these checks. **Implement:** `Install-Module ExchangeOnlineManagement`; `Install-Module Microsoft.Graph`; sign in with the role-holding admin and grant the read scopes the scripts request. Confirm the correct cloud endpoints for GCC/GCC High.

2.9 A pilot assessment and change control

Description: A named **pilot assessment** (`CMMC Assessment – NIST 800-171 – Pilot`) validated first — its action plan, evidence, and automatic-testing behaviour — before the full production assessment is built, plus a **change-control** path for any technical remediation an action triggers (consistent with `global-requirements-purview.md` §6). **Why:** Standing up every requirement at once produces an unmanageable action backlog; validating one assessment end-to-end proves the ownership, evidence, and testing model before scaling. Technical remediations are high-impact and are piloted in simulation/test under change control. **Verify:** A named pilot assessment and its owner exist; a change window/approval path for technical remediation is defined. **Implement:** Use the CMMC/NIST 800-171 template as the pilot, validate it end-to-end, then expand; agree change control before acting on any high-impact improvement action.

Checklist

- Licensing: Compliance Manager + CMMC Level 2 / NIST 800-171 premium template available — `CMMC-Discovery.ps1`
- Cloud confirmed for CUI (Commercial / GCC / GCC High) and template present in that cloud
- Compliance Manager role groups populated with least-privilege separation — `CMMC-Set-Scope.ps1`
- Compliance/security/legal owners named; target level + in-/out-of-scope requirements recorded (`CMMC Scope – Record`)
- CUI boundary + SSP defined
- Improvement-action owners + evidence sources identified (auto vs manual) — `CMMC-Configuration.ps1`
- Automatic-testing decision + underlying signals checked — `CMMC-Validation.ps1`
- S&C PowerShell + Graph toolchain (correct cloud endpoints) — `CMMC-Discovery.ps1`
- Pilot assessment named + change control for technical remediation

Global Requirements — Microsoft Purview Solutions

These requirements apply to **every** solution in the **Purview** category (implementing and managing Microsoft Purview, sensitivity & retention labels, DLP, data lifecycle & records, insider risk, communication compliance, audit, data security posture management, and data governance). Verify each before starting a solution's implementation steps.

> ***Vendor boundary (applies to every Purview solution).*** *The **Microsoft Purview portal** (purview.microsoft.com), the **Microsoft 365 admin center**, **Security & Compliance PowerShell***

*(`Connect-IPPSSession`), and **Microsoft Graph** are authored at exact, current click-by-click / cmdlet detail from Microsoft's public documentation. Microsoft Purview features are heavily **licensing-/plan-dependent** (many require **Microsoft 365 E5** or the **E5 Compliance** add-on; some are in preview) and the portal is **actively evolving** — capability availability and portal paths are **cited or flagged "verify your licensing/tenant"**, never asserted or invented. **Regulatory, records-retention, and legal determinations** (retention schedules, records file plans, legal holds, insider-risk case actions, regulatory applicability) are **deferred to the organization's compliance, records, privacy, and legal functions** — the solutions provide the technical configuration method and evidence, not the determination. Automation is **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets.*

1. Microsoft 365 tenant with the required Purview/compliance licensing

• **Description:** A Microsoft 365 tenant with the **compliance licensing** the capability requires

(E3 for baseline; **E5 / E5 Compliance** for advanced DLP, auto-labeling, insider risk, communication compliance, Audit Premium, DSPM, etc.).

• **Why required:** Most Purview capabilities are plan-gated; the feature won't be available without the

right plan.

• **How to verify:** In the M365 admin center confirm the subscription/add-ons; check the feature is

visible in the Purview portal.

• **How to implement if missing:** Assign/purchase the required licensing before starting.

2. Purview roles (least-privilege) and portal access

• **Description:** Access with the least-privilege **Purview / compliance role** the solution names

(e.g. Compliance Administrator, Compliance Data Administrator, Information Protection, Records Management, Insider Risk, eDiscovery, Audit roles), with Global Administrator only where required.

• **Why required:** Purview uses fine-grained role groups; configuration requires the matching role.

• **How to verify:** Purview portal → **Roles & scopes / Permissions** — confirm the role membership.

• **How to implement if missing:** Assign the least-privilege role group under change control.

3. Security & Compliance PowerShell + Graph toolchain

• **Description:** A workstation with **Security & Compliance PowerShell** (`Connect-IPPSSession` via the

ExchangeOnlineManagement module) and **Microsoft Graph PowerShell**, modern-auth / MFA-capable admin.

• **Why required:** Configuration, automation, and the provided scripts run through these.

• **How to verify:** `Connect-IPPSSession` and `Connect-MgGraph` succeed with the admin account.

• **How to implement if missing:** Install the modules and confirm modern-auth sign-in before running steps.

4. Data sources & scope in scope

• **Description:** The **workloads and data sources** in scope (Exchange, SharePoint, OneDrive, Teams, endpoints/devices, and — for data governance — the broader data estate) and a **data-classification / sensitivity** intent to drive labels, DLP, and retention.

• **Why required:** Purview policies key off the in-scope workloads and the classification scheme.

• **How to verify:** Confirm the in-scope workloads and the classification/sensitivity approach with stakeholders.

• **How to implement if missing:** Define the scope and classification intent before authoring policies.

5. Compliance, records, privacy & legal stakeholders

• **Description:** Engagement with the **compliance, records-management, privacy, security, and legal** stakeholders whose policies the configuration must satisfy (retention schedules, records file plans, regulatory obligations, insider-risk and communication-compliance policy, legal hold).

• **Why required:** Purview configuration must align to enterprise policy and legal/records requirements, not technical defaults; several capabilities have HR/legal sensitivity.

• **How to verify:** Confirm the applicable policies, the records schedule, and named approvers.

• **How to implement if missing:** Identify the owners and capture the requirements before configuring.

6. A pilot scope and change control

• **Description:** A **pilot scope** (users/sites/policies in simulation or a limited ring) to validate on before tenant-wide enforcement, and a **change-control** process — most Purview policies support a **simulation / test / disabled** mode that MUST be used before enforcement.

• **Why required:** Every solution follows an **Assess → Design → Configure → Pilot (simulate) → Validate → Expand (enforce)** model; DLP, labels, retention, and insider-risk changes are high-impact.

• **How to verify:** Confirm a named pilot scope, that simulation/test mode is available, and a change window/approval path.

• **How to implement if missing:** Define the pilot and agree change control before enforcing anything.

*The deployment model across every Purview solution is the same: **Assess** → **Design** → **Configure** → **Pilot (simulate/test)** → **Validate** → **Expand (enforce)**, with explicit pass/fail gates and a documented rollback. Automation is delivered as **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets. Regulatory/records/legal determinations are deferred to the relevant governance functions.*

3. Implementation Guide — Microsoft Purview CMMC Compliance Program

Follow these steps **in order**. Configuration is done in the **Microsoft Purview portal** (`https://purview.microsoft.com` → **Compliance Manager**) and, where automated, via **Security & Compliance PowerShell** (`Connect-IPPSSession`, for role groups and technical evidence) and **Microsoft Graph** (for licensing and Conditional Access/MFA evidence). Artifact names follow the `<Purpose> – <Scope> – <Stage>` convention from the Overview and are reused verbatim. **Portal paths, template availability, cloud (Commercial vs GCC/GCC High), and cmdlets are plan-/cloud-dependent and the portal evolves — verify against your tenant.**

The named objects created below are reused verbatim in Testing, Troubleshooting, and the scripts:

Object	Name
Pilot assessment	`CMMC Assessment – NIST 800-171 – Pilot`
Production assessment	`CMMC Assessment – Level 2 – Production`
Improvement-action plan	`CMMC Action Plan – Pilot`
Control map	`CMMC Control Map – NIST 800-171`
Evidence register	`CMMC Evidence – Register`
Automatic-testing setting	`CMMC Automatic Testing – Setting`
Score posture report	`CMMC Score Posture – Report`
Role-separation evidence	`CMMC Roles – Separation Evidence`
Scope / CUI-boundary record	`CMMC Scope – Record`

> ***Model:*** *Baseline the posture, design the assessment/scope/owners, configure roles + the assessment + the action plan + control map + automatic testing, validate the evidence behind the actions, report, then expand. Pattern:* ***Assess*** *→* ***Design*** *→* ***Configure*** *→* ***Pilot (simulate/test)*** *→* ***Validate*** *→* ***Expand. Compliance Manager measures — it does not certify.*** *Any *technical* remediation an improvement action recommends (audit, DLP, MFA/Conditional Access, retention, labels, encryption) is a* ***separate, piloted change*** *owned by that feature's solution; and* ***CMMC applicability, the target level, evidence adequacy, the SPRS score, and certification are compliance/security/legal/C3PAO determinations****, not decisions this guide makes.*

Step 1 — Baseline the posture and capture role/licensing readiness (Assess)

1. Confirm licensing and cloud (Requirements 2.1–2.2): in the portal → **Compliance Manager →

Assessment templates**, the** CMMC Level 2 **and/or** NIST SP 800-171 **template shows as available in your cloud.** Verify entitlement and template name with Microsoft licensing — do not assume.**

1. Run `CMMC-Discovery.ps1` (read-only). It reports the licensing SKUs it can read, the membership of

each Compliance Manager role group (the `CMMC Roles – Separation Evidence` snapshot), and flags any administrator who is also a contributor. Note the current **Compliance Score** from the portal dashboard as your starting point.

1. **Pass/fail gate:** licensing/cloud confirmed for the CMMC/NIST template, the Compliance Manager

role groups exist, and the baseline score is recorded. **Do not proceed** until the governance owners (Requirement 2.4) have confirmed the **target level** and which requirements are in scope. Fail → resolve before configuring.

Step 2 — Assign roles with least-privilege separation (Configure — guardrails)

1. Portal → `Settings → Roles & scopes → Permissions`: populate the Compliance Manager role groups

(Requirement 2.3):

- **Compliance Manager Administrators** → the program owners / IT config staff.
- **Compliance Manager Assessors** → assessment leads who create assessments and set **test** status.
- **Compliance Manager Contributors** → the improvement-action **owners** who update actions/evidence.
- **Compliance Manager Readers** → oversight/auditors and any external **C3PAO reader**, **read-only**.

1. Or manage membership with `CMMC-Set-Scope.ps1` — it composes `Add-RoleGroupMember` / `Remove-RoleGroupMember`. **It runs with `-WhatIf` by default** and prints exactly what it would change; add `-Commit` to apply. Grant the **minimum** role each person needs.

1. **Pass/fail gate:** each person holds the least-privilege role; administrators are separated from

contributors; readers/auditors are read-only. Re-run `CMMC-Discovery.ps1` and confirm the `CMMC Roles – Separation Evidence` snapshot. **Rollback:** remove any over-granted membership with `CMMC-Set-Scope.ps1 -Commit`.

Step 3 — Design the assessment, CUI boundary, and owners (Design)

1. With the governance owners, confirm the **target CMMC level** and the **in-scope NIST 800-171

requirements **(Requirement 2.4), and the** CUI boundary/enclave **and** SSP **(Requirement 2.5).** Applicability, the level, and the boundary are the owners' determinations**, not technical defaults.

1. Decide how domains are **grouped** (by the 14 NIST 800-171 families) so control mapping and

reporting are coherent, and assign a **business owner** per domain.

1. Record the design as `CMMC Scope – Record` (target level, CUI boundary, SSP reference, in-/out-of-

scope requirements, grouping, owners).

Step 4 — Create the pilot assessment (Configure — pilot-first)

1. Portal → **Compliance Manager** → **Assessments** → **Add assessment**: create

`CMMC Assessment – NIST 800-171 – Pilot` from the **CMMC Level 2** / **NIST SP 800-171** template, in the agreed group. (The premium template requires the entitlement from Requirement 2.1.)

1. **Keep the pilot to one assessment.** Validating one CMMC assessment end-to-end — ownership,

evidence, automatic testing — proves the model before you build the production set. Compliance Manager does not change your tenant, so creating the assessment is safe; the *work* it surfaces (the improvement actions) is what you pilot.

1. **Pass/fail gate:** the pilot assessment exists in the correct group with an owner, and its

improvement actions and current score are visible. Fail → check template availability/licensing/cloud. **Rollback:** an assessment can be removed in the portal without affecting tenant configuration.

Step 5 — Build the action plan, control map, and evidence register (Configure)

1. For `CMMC Assessment – NIST 800-171 – Pilot`, assign each **improvement action** an **owner**, a

target date, and an **implementation status**, in the portal (action → **Assign** / edit).

1. Use `CMMC-Configuration.ps1` to build the tracking artifacts from the owner-provided list — it

validates the plan and, with `-Commit`, writes the local `CMMC Action Plan – Pilot`, `CMMC Control Map – NIST 800-171` (requirement/family → action → owner → evidence), and `CMMC Evidence – Register` files. **It runs with** `-WhatIf` **by default** and only *describes* the plan; **it makes no tenant changes** — Compliance Manager has no write API, so assignments and evidence upload happen in the portal, driven by these artifacts.

1. Attach **evidence** to each action in the portal (documents, test results, SSP/POA&M references) and

record its source in the register.

1. **Pass/fail gate:** every pilot action is mapped to its NIST 800-171 requirement/family and has an

owner, a target date, a status, and a named evidence source. Fail → complete the plan before validating.

Step 6 — Enable automatic testing where it applies (Configure)

1. Portal → **Compliance Manager** → **Settings**: set the **automatic testing** option

(`CMMC Automatic Testing – Setting`) per the governance owners' decision (Requirement 2.7). Eligible improvement actions will update their **test status** from your Microsoft 365 configuration signals.

1. Run `CMMC-Validation.ps1` (read-only) to confirm the **underlying technical signals** the automatable

NIST 800-171 actions depend on are present — e.g. **unified audit logging enabled** (AU), **Conditional Access / MFA** configured (AC/IA), **DLP / retention / sensitivity-label / encryption** policies present (MP/SC). This tells you which actions can auto-pass and which still need **manual** evidence.

1. **Pass/fail gate:** automatic testing is set as agreed, and you know which actions are auto-tested vs

manual-evidence. Fail → enable automatic testing or record the manual-evidence actions.

Step 7 — Validate the evidence behind the actions (Pilot → Validate)

1. Run the Testing Guide (`05-testing.md`). Confirm: the pilot assessment shows a score; each action's

implementation and **test** status is set with **evidence**; automatic-tested actions reflect the real technical state (cross-checked by `CMMC-Validation.ps1`); role separation holds.

1. Where an action recommends a **technical change** (enable audit, add a DLP/retention/label/encryption

policy, tighten Conditional Access/MFA), **pilot that change in simulation/test first** under its own change control — those high-impact changes are owned by their feature's solution, not switched on blind here. Re-run `CMMC-Validation.ps1` to capture the new evidence.

1. Run `CMMC-Report.ps1` for the `CMMC Score Posture – Report` (score, action-status rollup, control-map

coverage by NIST 800-171 family, evidence register, role separation, licensing).

1. **Pass/fail gate:** the pilot assessment is fully owned, evidenced, and tested; automatic testing

reflects reality; the posture report is accurate. Fail → complete evidence/testing and re-validate. **Whether the posture satisfies CMMC is a compliance/C3PAO determination, not this gate.**

Step 8 — Expand to the full CMMC set and run the cadence (Expand)

1. With the governance owners, create the production assessment(s) — `CMMC Assessment – Level 2 –

Production` (and any additional frameworks) — from the licensed template(s), in the agreed grouping. **Lean on control mapping:** actions already implemented in the pilot often satisfy the same NIST 800-171 requirement in the production assessment automatically (shared controls), so the incremental effort is the *gap*.

1. Extend the **action plan**, **control map**, and **evidence register** to the production assessment

(owners, dates, evidence) with `CMMC-Configuration.ps1`.

1. Stand up the **maintenance cadence** toward the C3PAO assessment: periodic re-test/re-evidence of

actions, review of owners (joiners/leavers), keeping the **SSP/POA&M** current, watching for **template/regulation updates** Microsoft publishes, and re-running `CMMC-Report.ps1` on a schedule for the posture trend.

1. **Pass/fail gate:** the full in-scope set exists, is owned and evidenced, automatic testing is

running, and a recurring review is scheduled. **Rollback:** any assessment can be removed in the portal without touching tenant configuration; scope can be narrowed at any time.

What this guide does NOT decide

• **CMMC applicability, the target level, whether the evidence satisfies a requirement, the NIST

800-171 DoD Assessment Methodology / SPRS score, and certification **— these are** compliance/security/legal/C3PAO determinations**. This guide configures the assessment, the action plan,

the control map, and the evidence, and produces the score and posture; adequacy, scoring, and sign-off belong to those functions and the assessor.

- **The high-impact technical changes an action recommends** — enabling audit, DLP, retention, labels,

encryption, Conditional Access/MFA, etc. are **separate, piloted-in-simulation** changes owned by their own solution; Compliance Manager only measures whether they are in place.

Order of operations

`Baseline → roles (separation) → design scope/boundary/owners → create pilot assessment → action plan + control map + evidence → automatic testing → validate evidence → posture report → expand to production + cadence`

5. Testing Guide — Microsoft Purview CMMC Compliance Program

Run these after assigning roles (Step 2) and building the pilot assessment, action plan, control map, and automatic testing (Steps 4–6), and again after each change and before expanding. Every test here is **safe and read-only** or contained to the **pilot assessment** — Compliance Manager itself changes nothing on the tenant; the point is to prove the **score, ownership, evidence, control mapping, automatic testing, and role separation** all work before you build the full CMMC set. **Adequacy, scoring, and certification remain a compliance/C3PAO determination — these tests validate the mechanism.**

Test 1 — Role separation is in place (the access guardrail)

Do: Run `CMMC-Discovery.ps1`; review the `CMMC Roles – Separation Evidence` snapshot of each Compliance Manager role group's membership. **Expected:** Administrators are separated from contributors; assessors set test status; readers/ auditors (and any external C3PAO reader) are **read-only**. No administrator is silently also a contributor unless the governance owners accepted it. **Fail** → correct membership with `CMMC-Set-Scope.ps1` (Implementation Step 2) before proceeding.

Test 2 — Licensing/cloud supports the CMMC template

Do: Run `CMMC-Discovery.ps1` and, in the portal → **Compliance Manager** → **Assessment templates**, confirm the **CMMC Level 2** / **NIST SP 800-171** template is available to create in your cloud. **Expected:** The template shows as available under your entitlement, in the correct cloud (Commercial / GCC / GCC High). **Fail** → resolve licensing/cloud (Requirements 2.1–2.2) before creating the assessment.

Test 3 — The pilot assessment exists and is scored

Do: In the portal → **Compliance Manager** → **Assessments**, open `CMMC Assessment – NIST 800-171 – Pilot`. **Expected:** The assessment is in the agreed group, has an owner, and shows a **Compliance Score** and its improvement actions across the NIST 800-171 families. **Fail** → recreate/repair the assessment (Implementation Step 4).

Test 4 — Every pilot action is mapped and has an owner, date, status, and evidence source

Do: Run `CMMC-Report.ps1`; review the `CMMC Action Plan – Pilot` / `CMMC Control Map – NIST 800-171` / `CMMC Evidence – Register` rollup against the assessment's actions in the portal. **Expected:** Each improvement action maps to a **NIST 800-171 requirement/family** and has an **owner**, a **target date**, an **implementation status**, and a **named evidence source**; nothing is unassigned. **Fail** → complete the plan with `CMMC-Configuration.ps1` and assign in the portal.

Test 5 — Automatic testing reflects the real technical state (true evidence)

Do: Confirm automatic testing is enabled (`CMMC Automatic Testing – Setting`), then run `CMMC-Validation.ps1` (read-only) and compare its findings to the auto-tested actions' status. **Expected:** For an action Compliance Manager auto-tests (e.g. **unified audit logging enabled** for the AU family, **MFA/Conditional Access** for AC/IA), the tool's finding matches the action's **test status** — the score reflects reality, not a stale value. **Fail** → confirm auto-testing eligibility and the underlying signal; some actions need manual evidence.

Test 6 — A not-yet-implemented control scores as such (no false pass)

Do: Pick an improvement action whose technical control is **not** in place; check its status in the portal and cross-check with `CMMC-Validation.ps1`. **Expected:** The action shows **Not implemented / not tested** (or Failed), and the tool confirms the control is absent — the score is **not** inflated, and the gap is a candidate for the **POA&M**. **Fail** → correct the status/evidence; do not mark implemented without proof.

Test 7 — Manual evidence is attached and defensible

Do: Open two or three manually-evidenced actions in the portal; confirm the uploaded **evidence** (policy, procedure, SSP/POA&M reference), **owner**, and **test date** are present, and that `CMMC Evidence – Register` records the source. **Expected:** Each manual action carries proof, an owner, and a date — an assessor-ready record. **Fail** → attach the evidence and record it in the register.

Test 8 — Control mapping / shared controls behave as expected

Do: After the pilot actions are implemented, create the production assessment (or a second framework) from a licensed template and inspect the shared/mapped controls. **Expected:** Controls already satisfied by pilot actions show as **implemented** in the new assessment via **shared/control mapping** — you did not have to redo the work. **Fail** → verify the action is a shared/Microsoft-managed control and its status is set.

Test 9 — Posture report is accurate and complete

Do: Run `CMMC-Report.ps1` for the `CMMC Score Posture – Report`. **Expected:** The report rolls up the score, the action-status breakdown, the control-map coverage by NIST 800-171 family, the evidence register, the role-separation snapshot, and the licensing — matching the portal. It notes that the **authoritative score and export** are the portal's Compliance Manager export and that the **SPRS score/certification** are separate determinations. **Fail** → confirm inputs and re-run.

Test 10 — Safe automation defaults

Do: Run `CMMC-Configuration.ps1` and `CMMC-Set-Scope.ps1` with no action switch. **Expected:** Each runs in `-WhatIf` mode and only *describes* the change; nothing is written until `-Commit` is supplied. `CMMC-Discovery.ps1`, `CMMC-Validation.ps1`, and `CMMC-Report.ps1` are read-only. **Fail** → stop; do not run with `-Commit` until the dry-run output is correct.

Gate to expand: Tests 1–2 (guardrails + licensing/cloud), 3–4 (assessment + mapping/ownership), 5–7 (evidence accuracy), 8 (control mapping), and 9–10 (reporting + safety) all pass for the pilot → proceed to the production assessment (Implementation Step 8). Any fail → correct and re-test. **Whether the resulting score/evidence satisfies CMMC is a compliance/C3PAO decision, not a technical one.**

6. Troubleshooting Guide — Microsoft Purview CMMC Compliance Program

Use `CMMC-Discovery.ps1` for readiness, roles, and licensing; `CMMC-Validation.ps1` to confirm the technical signals behind the NIST 800-171 actions; `CMMC-Report.ps1` for the `CMMC Score Posture -Report`; `CMMC-Configuration.ps1` (default `-WhatIf`) to build the action-plan/control-map/evidence artifacts; and `CMMC-Set-Scope.ps1` (default `-WhatIf`) for least-privilege role membership. **Portal paths, template names, and cmdlets are plan-/cloud-dependent and evolve — verify against your tenant.**

A. The CMMC / NIST 800-171 template is not available to create

Symptom	Cause	Remediation
Template missing from **Assessment templates**	Premium template not entitled (needs E5 / E5 Compliance / Premium Assessment Add-On)	Verify licensing (Requirement 2.1); run `CMMC-Discovery.ps1` for the SKUs; assign the entitlement
Template present but "0 remaining"	Premium **assessment count** exhausted for your seats	Free an assessment or add entitlement; the *number* of premium assessments is seat-gated
Template named differently / absent in your cloud	GCC/GCC High feature and naming differences	Confirm the tenant cloud (Requirement 2.2) and the template's availability **in that cloud** with Microsoft

B. Compliance Manager role groups missing or misnamed

- `CMMC-Discovery.ps1` / `CMMC-Set-Scope.ps1` reports a role group "not found": Purview role naming

evolves and differs by cloud. **Verify the exact role-group name** in the portal → `Settings → Roles & scopes → Permissions` and pass it to `-RoleGroup`.

- No members returned: confirm the signed-in admin can read role groups (Compliance Administrator /

Global Reader) and that membership was actually assigned.

C. Separation-of-duty flag (admin is also a contributor)

- `CMMC-Discovery.ps1` flags an account in both **Administrators** and **Contributors**. This is a least-privilege / Access Control concern. Either accept it explicitly with the governance owners, or remove the excess membership with `CMMC-Set-Scope.ps1 -RoleGroup 'Compliance Manager Administrators' -Remove <user> -Commit`. Keep readers/auditors and any external C3PAO reader **read-only**.

D. Automatic testing not updating an action's status

- Confirm the **automatic testing** option is enabled: portal → **Compliance Manager** → **Settings** (`CMMC Automatic Testing – Setting`).
- Only **eligible** actions auto-test, and only when the **underlying signal** exists. Run `CMMC-Validation.ps1`: if it reports a **GAP** for the family (e.g. audit off, no MFA CA policy), the action cannot auto-pass — either remediate the control (piloted in simulation/test) or supply **manual** evidence.
- Signals can take time to propagate; re-check after the tenant change settles.

E. Score looks too high or too low (false pass / false gap)

- **Too high:** an action is marked **Implemented** without proof. Cross-check with `CMMC-Validation.ps1`; if the control is absent, set the action back to *Not implemented* and route it to the **POA&M**. Never mark implemented without evidence.
- **Too low:** a genuinely-implemented control lacks status/evidence in the portal, or an action is **manual** and no evidence was attached. Complete the `CMMC Evidence – Register` and set the status.
- Remember: the **authoritative score/export** is the portal's Compliance Manager export — reconcile to it, not to a script.

F. `CMMC-Validation.ps1` reports a gap you believe is covered

Symptom	Cause	Remediation
MFA gap but MFA is on	MFA enforced via Security Defaults or per-user MFA, not a Conditional Access policy	The script reads **CA** policies; record MFA as **manual** evidence, or implement MFA via CA to make it auto-testable
DLP/label/retention gap but policies exist	Signed-in account lacks read rights, or wrong cloud endpoint	Ensure the compliance read roles; for GCC High pass `-ExoConnectionUri` / `-GraphEnvironment`

Symptom	Cause	Remediation
Graph section errors	Graph module/scope not consented	`Install-Module Microsoft.Graph`; consent `Policy.Read.All` / `Organization.Read.All`

G. `CMMC-Configuration.ps1` won't write the artifacts

- It runs `-WhatIf` by default — pass `-Commit` to write.
- It refuses to commit while **field problems** remain: every row needs `Requirement, Family, Action,

Owner, TargetDate, ImplementationStatus, TestMethod (Automatic|Manual), EvidenceSource`. Fix the input CSV and re-run. It makes **no tenant changes** by design — assignments and evidence upload happen in the portal.

H. GCC / GCC High connection issues

- Default endpoints target the Commercial cloud. For government clouds pass `-ExoConnectionUri` (the

environment's S&C PowerShell URI) and `-GraphEnvironment` (`USGov` / `USGovDoD`) to the scripts, and confirm the account exists in that tenant/cloud.

I. Diagnostics quick reference

```
# Security & Compliance PowerShell (Exchange Online Management module)
Connect-IPPSSession    # add -ConnectionUri <gov URI> for GCC High
Get-RoleGroup | Where-Object Name -like 'Compliance Manager*' | Select-Object Name
Get-RoleGroupMember 'Compliance Manager Contributors' | Select-Object Name
(Get-AdminAuditLogConfig).UnifiedAuditLogIngestionEnabled   # AU signal
Get-DlpCompliancePolicy | Select-Object Name, Mode
Get-Label | Select-Object DisplayName, Priority
Get-RetentionCompliancePolicy | Select-Object Name, Enabled
```

The **assessment score, improvement-action status, evidence upload, and export** are managed in the Purview **Compliance Manager** portal — the scripts assess readiness and the evidence *behind* the actions; they do not set assessment status.

J. What this guide never resolves (by design)

- **Whether the evidence satisfies a CMMC requirement, the target level, the NIST 800-171 DoD

Assessment Methodology / SPRS score, and certification **— these are** compliance/security/legal/C3PAO determinations**. If a stakeholder asks "are we certified?", the answer comes from the assessor, not from Compliance Manager or these scripts.

K. When to escalate

If licensing and cloud are confirmed, the template is available, roles are correct, the underlying signals pass in `CMMC-Validation.ps1`, and Compliance Manager still does not reflect an action's state after the

change has propagated, collect the output of `CMMC-Discovery.ps1`, `CMMC-Validation.ps1`, and `CMMC-Report.ps1` and open a Microsoft support case (specify your cloud — Commercial / GCC / GCC High).

7. Best Practices — Microsoft Purview CMMC Compliance Program

- **Measure before you certify.** Compliance Manager gives you a defensible **posture and evidence**;

it does not certify. Treat the score as your internal readiness signal and the **C3PAO assessment** as the determination — keep the two clearly separated so nobody mistakes a green score for a certificate.

- **Confirm the cloud first.** For CUI, verify whether you must run in **GCC High** (or GCC) *before*

building — template availability, portal paths, and cmdlets differ, and building in the wrong cloud is rework and, for regulated CUI, a compliance failure.

- **Verify template availability, don't assume it.** The **CMMC Level 2 / NIST SP 800-171** template is

premium and entitlement-gated, and its exact name evolves. Confirm it shows as *available to create* in your tenant and cloud before you promise a timeline.

- **Pilot one assessment end-to-end.** Validate ownership, evidence, and automatic testing on

`CMMC Assessment – NIST 800-171 – Pilot` before building the production set. One clean assessment proves the model; ten half-owned ones prove nothing.

- **Map every action to its requirement.** Keep `CMMC Control Map – NIST 800-171` current so each

improvement action is traceable to a NIST 800-171 requirement and family — that traceability is what a C3PAO reviews, and it is how you spot which of the 110 requirements are still uncovered.

- **Separate roles as a control, not a formality.** Least-privilege separation of Compliance Manager

administrators, contributors, and read-only readers/assessors is itself an Access Control requirement — and it keeps your evidence defensible because access to it was governed.

- **Never mark implemented without proof (no false pass).** Set an action to Implemented only when the

evidence exists; let genuinely-absent controls score as gaps and route them to the **POA&M**. An inflated score is the fastest way to fail a C3PAO assessment.

- **Automatic testing where it's real, manual evidence everywhere else.** Enable automatic testing so

technical actions (audit, MFA/Conditional Access, DLP/retention/labels/encryption) self-update — but cross-check with `CMMC-Validation.ps1`, and don't assume auto-coverage for actions that need policy/procedure evidence.

- **Pilot high-impact technical remediation in simulation/test.** When an action recommends enabling

DLP, encryption, retention, or tighter Conditional Access, roll it out in simulation/test under change control first — those are owned by their feature's solution, not switched on blind to chase a point.

• **Keep the SSP and POA&M as living documents.** The assessment measures against the **CUI boundary

and SSP**; keep them, the evidence register, and the owners current on a cadence so the program is audit-ready continuously, not just before an assessment.

• **Report the trend, not just the number.** Run `CMMC-Report.ps1` on a schedule so leadership sees

coverage-by-family moving toward the target level, and so remaining gaps have owners and dates ahead of the C3PAO engagement.

8. Deliverables Summary — Microsoft Purview CMMC Compliance Program

Documentation

Document	Purpose
Executive Summary	Business case and what's in the box
1. Solution Overview	What a Purview-backed CMMC program is — Compliance Manager, the CMMC Level 2 / NIST 800-171 template, control mapping, evidence — benefits, limitations, C3PAO boundary
2. Requirements Guide	Every prerequisite with Verify / Implement-if-missing (licensing, cloud, roles, CUI boundary/SSP, owners)
Global Requirements (Purview)	Category-wide prerequisites, published once
3. Implementation Guide	Exact, ordered Purview portal + PowerShell/Graph steps (baseline, roles, assessment, action plan + control map, automatic testing, validate, expand)
5. Testing Guide	Validation procedures with pass/fail gates
6. Troubleshooting Guide	Field issues and remediation
7. Best Practices	Field-proven recommendations

PowerShell scripts

Script	What it does	Safe default
`CMMC-Discovery.ps1`	Reports licensing SKUs, the Compliance Manager role-group membership (`CMMC Roles – Separation Evidence`), and audit-log readiness; flags admins who are also contributors	Read-only

Script	What it does	Safe default
`CMMC-Validation.ps1`	Confirms the underlying technical signals behind automatable NIST 800-171 actions (unified audit AU, MFA/Conditional Access AC/IA, DLP/retention/label/encryption MP/SC)	Read-only
`CMMC-Report.ps1`	`CMMC Score Posture – Report` — role separation, technical-signal coverage by family, licensing; notes the authoritative score/SPRS are separate	Read-only
`CMMC-Configuration.ps1`	Builds the local `CMMC Action Plan – Pilot`, `CMMC Control Map – NIST 800-171`, and `CMMC Evidence – Register` from the owner-provided list (no tenant write — Compliance Manager has no write API)	`-WhatIf` unless `-Commit`
`CMMC-Set-Scope.ps1`	Assigns/removes Compliance Manager role-group membership for least-privilege separation	`-WhatIf` unless `-Commit`

What the buyer receives

- This implementation guide as a branded Word document and PDF.
- All five PowerShell scripts in a single ZIP (read-only or `-WhatIf` by default; no credentials in code).
- A repeatable process following the model: **Assess → Design → Configure → Pilot (simulate/test) → Validate → Expand**, with pass/fail gates, a documented rollback, and CMMC certification / assessment determinations deferred to the C3PAO and compliance/security/legal.

Outcome

A **defensible, evidenced CMMC compliance program in Microsoft Purview** — the CMMC Level 2 / NIST 800-171 requirements mapped to configured controls and owned improvement actions, technical evidence validated from the tenant, automatic testing where it applies, and a maintained posture report — proven on a pilot assessment before you scale toward the C3PAO assessment. The certification determination remains the assessor's; this delivers the program and the evidence that make it defensible.

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

CMMC-Configuration.ps1

Purpose: Turns an owner-provided list of improvement actions into the three local tracking artifacts this solution maintains — 'CMMC Action Plan - Pilot', 'CMMC Control Map - NIST 800-171' (requirement/ family -> action -> owner -> evidence), and 'CMMC Evidence - Register' (CSV files). It validates the input (owner, target date, NIST 800-171 requirement, evidence source, auto-vs-manual) and, only with -Commit, writes the CSVs. It makes NO tenant changes: Compliance Manager has no public write API, so assignments and evidence upload happen in the portal, DRIVEN BY these artifacts. HOW TO RUN Preview (safe, default): powershell -ExecutionPolicy Bypass -File .\CMMC-Configuration.ps1 -InputCsv .\actions.csv Write the artifacts: powershell -ExecutionPolicy Bypass -File .\CMMC-Configuration.ps1 -InputCsv .\actions.csv -Commit -OutDir .\cmmc-artifacts Input CSV columns: Requirement,Family,Action,Owner,TargetDate,ImplementationStatus,TestMethod,EvidenceSource (TestMethod = Automatic|Manual). With no -InputCsv, a template header is written for you to fill. EXPECTED RESULTS WhatIf: a validated summary of what WOULD be written (rows, any missing fields), no files. -Commit: the three CSV artifacts written to -OutDir. No tenant/portal changes are ever made. .NOTES White-label — Purview Solutions. Default is a dry run; local file writes only with -Commit. No cmdlets, no credentials, no tenant writes — Compliance Manager is portal-managed. > [CmdletBinding()] param([string]$InputCsv, [string]$OutDir = '.\cmmc-artifacts', [switch]$Commit) $WhatIf = -not $Commit $mode = $(if($WhatIf){'WHATIF (preview only — no files written)'}else{'COMMIT (writing local artifacts)'}) Write-Host ("`n=== CMMC configuration artifacts [{0}] ===" -f $mode) -ForegroundColor Cyan

How to run: Preview (safe, default): powershell -ExecutionPolicy Bypass -File .\CMMC-Configuration.ps1 -InputCsv .\actions.csv Write the artifacts: powershell -ExecutionPolicy Bypass -File .\CMMC-Configuration.ps1 -InputCsv .\actions.csv -Commit -OutDir .\cmmc-artifacts Input CSV columns: Requirement,Family,Action,Owner,TargetDate,ImplementationStatus,TestMethod,EvidenceSource (TestMethod = Automatic|Manual). With no -InputCsv, a template header is written for you to fill. EXPECTED RESULTS WhatIf: a validated summary of what WOULD be written (rows, any missing fields), no files. -Commit: the three CSV artifacts written to -OutDir. No tenant/portal changes are ever made. .NOTES White-label — Purview Solutions. Default is a dry run; local file writes only with -Commit. No cmdlets, no credentials, no tenant writes — Compliance Manager is portal-managed. > [CmdletBinding()] param([string]$InputCsv, [string]$OutDir = '.\cmmc-artifacts', [switch]$Commit) $WhatIf = -not $Commit $mode = $(if($WhatIf){'WHATIF (preview only — no files written)'}else{'COMMIT (writing local artifacts)'}) Write-Host ("`n=== CMMC configuration artifacts [{0}] ===" -f $mode) -ForegroundColor Cyan

CMMC-Discovery.ps1

Purpose: Reports the tenant readiness to stand up a CMMC (NIST SP 800-171 / CMMC Level 2) program in Microsoft Purview Compliance Manager: the licensing SKUs it can read via Graph, the membership of each Compliance Manager role group (the 'CMMC Roles - Separation Evidence' snapshot, flagging any administrator who is also a contributor), and whether unified audit logging is on. It does NOT create assessments — Compliance Manager is portal-managed and has no write API. HOW TO RUN Install-Module ExchangeOnlineManagement -Scope CurrentUser Install-Module Microsoft.Graph -Scope CurrentUser powershell -ExecutionPolicy Bypass -File .\CMMC-Discovery.ps1 Sign in as a Compliance Administrator / Global Reader when prompted. For GCC High, pass the environment endpoints:

-ExoConnectionUri and -GraphEnvironment (see params). EXPECTED RESULTS Licensing SKU list, per-role-group membership with any admin+contributor overlap flagged, and an audit-logging state line. Read-only — makes no changes. .NOTES White-label — Purview Solutions. Read-only. Uses Get-RoleGroupMember / Get-AdminAuditLogConfig (S&C PowerShell) and Get-MgSubscribedSku (Graph). Verify exact role-group names, template availability, and cloud (Commercial vs GCC/GCC High) in your own tenant — Purview naming evolves; nothing here is assumed. > [CmdletBinding()] param([string]$ExoConnectionUri, # e.g. GCC High: https://ps.compliance.protection.office365.us/powershell-liveid/ [string]$GraphEnvironment = 'Global' # e.g. 'USGov' or 'USGovDoD' for government clouds)

How to run: Install-Module ExchangeOnlineManagement -Scope CurrentUser Install-Module Microsoft.Graph -Scope CurrentUser powershell -ExecutionPolicy Bypass -File .\CMMC-Discovery.ps1 Sign in as a Compliance Administrator / Global Reader when prompted. For GCC High, pass the environment endpoints: -ExoConnectionUri and -GraphEnvironment (see params). EXPECTED RESULTS Licensing SKU list, per-role-group membership with any admin+contributor overlap flagged, and an audit-logging state line. Read-only — makes no changes. .NOTES White-label — Purview Solutions. Read-only. Uses Get-RoleGroupMember / Get-AdminAuditLogConfig (S&C PowerShell) and Get-MgSubscribedSku (Graph). Verify exact role-group names, template availability, and cloud (Commercial vs GCC/GCC High) in your own tenant — Purview naming evolves; nothing here is assumed. > [CmdletBinding()] param([string]$ExoConnectionUri, # e.g. GCC High: https://ps.compliance.protection.office365.us/powershell-liveid/ [string]$GraphEnvironment = 'Global' # e.g. 'USGov' or 'USGovDoD' for government clouds)

CMMC-Report.ps1

Purpose: Produces the 'CMMC Score Posture - Report': the Compliance Manager role-separation snapshot, a coverage summary of the technical signals behind automatable NIST 800-171 actions grouped by family, and the licensing entitlement — the internal readiness picture you review before the C3PAO assessment. It explicitly notes that the AUTHORITATIVE score/export live in the Purview Compliance Manager portal, and that the SPRS score and certification are separate determinations. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\CMMC-Report.ps1 -CsvPath C:\Temp\cmmc-posture.csv Sign in as a Compliance Administrator / Global Reader when prompted. For GCC High pass -ExoConnectionUri / -GraphEnvironment as in CMMC-Discovery.ps1. EXPECTED RESULTS A role-separation table, a family-by-family technical-signal coverage table, and a licensing line, optionally exported to CSV. Read-only — makes no changes. .NOTES White-label — Purview Solutions. Read-only. Reuses read-only calls (Get-RoleGroupMember, Get-AdminAuditLogConfig, Get-DlpCompliancePolicy, Get-Label, Get-RetentionCompliancePolicy, Get-MgSubscribedSku). Not the authoritative score — the portal Compliance Manager export is; SPRS/certification are compliance/C3PAO determinations. > [CmdletBinding()] param([string]$CsvPath, [string]$ExoConnectionUri, [string]$GraphEnvironment = 'Global')

How to run: powershell -ExecutionPolicy Bypass -File .\CMMC-Report.ps1 -CsvPath C:\Temp\cmmc-posture.csv Sign in as a Compliance Administrator / Global Reader when prompted. For GCC High pass -ExoConnectionUri / -GraphEnvironment as in CMMC-Discovery.ps1. EXPECTED RESULTS A role-separation table, a family-by-family technical-signal coverage table, and a licensing line, optionally exported to CSV. Read-only — makes no changes. .NOTES White-label — Purview Solutions. Read-only. Reuses read-only calls (Get-RoleGroupMember, Get-AdminAuditLogConfig, Get-DlpCompliancePolicy, Get-Label, Get-RetentionCompliancePolicy, Get-MgSubscribedSku). Not the authoritative score — the portal Compliance Manager export is; SPRS/certification are compliance/C3PAO

determinations. > [CmdletBinding()] param([string]$CsvPath, [string]$ExoConnectionUri, [string]$GraphEnvironment = 'Global')

CMMC-Set-Scope.ps1

Purpose: Manages membership of the Compliance Manager role groups so administrators are separated from action contributors and read-only readers/assessors (the CMMC Access Control / least-privilege guardrail). It composes Add-RoleGroupMember / Remove-RoleGroupMember for a named role group and the supplied members. It runs with -WhatIf by DEFAULT (previews only); pass -Commit to apply. It never deletes a role group and never grants more than the named role. HOW TO RUN Preview (safe, default): powershell -ExecutionPolicy Bypass -File .\CMMC-Set-Scope.ps1 -RoleGroup 'Compliance Manager Contributors' -Add user1@contoso.com,user2@contoso.com Apply: powershell -ExecutionPolicy Bypass -File .\CMMC-Set-Scope.ps1 -RoleGroup 'Compliance Manager Contributors' -Add user1@contoso.com -Commit Remove: powershell -ExecutionPolicy Bypass -File .\CMMC-Set-Scope.ps1 -RoleGroup 'Compliance Manager Administrators' -Remove olduser@contoso.com -Commit Sign in with rights to manage role groups when prompted. For GCC High pass -ExoConnectionUri. EXPECTED RESULTS WhatIf: the exact Add/Remove it WOULD perform. -Commit: the membership changes applied, then a re-print of the group's membership. Verify the exact role-group name in your tenant first. .NOTES White-label — Purview Solutions. Default is a dry run; changes only with -Commit. No credentials. Uses Add-RoleGroupMember / Remove-RoleGroupMember / Get-RoleGroupMember (S&C PowerShell). Purview role naming evolves — confirm the role-group name (e.g. via CMMC-Discovery.ps1) before committing. > [CmdletBinding()] param([Parameter(Mandatory=$true)] [ValidateSet('Compliance Manager Administrators', 'Compliance Manager Assessors', 'Compliance Manager Contributors', 'Compliance Manager Readers')] [string]$RoleGroup, [string[]]$Add = @(), [string[]]$Remove = @(), [switch]$Commit, [string]$ExoConnectionUri) $WhatIf = -not $Commit $mode = $(if($WhatIf){'WHATIF (preview only)'}else{'COMMIT (applying changes)'})

How to run: Preview (safe, default): powershell -ExecutionPolicy Bypass -File .\CMMC-Set-Scope.ps1 -RoleGroup 'Compliance Manager Contributors' -Add user1@contoso.com,user2@contoso.com Apply: powershell -ExecutionPolicy Bypass -File .\CMMC-Set-Scope.ps1 -RoleGroup 'Compliance Manager Contributors' -Add user1@contoso.com -Commit Remove: powershell -ExecutionPolicy Bypass -File .\CMMC-Set-Scope.ps1 -RoleGroup 'Compliance Manager Administrators' -Remove olduser@contoso.com -Commit Sign in with rights to manage role groups when prompted. For GCC High pass -ExoConnectionUri. EXPECTED RESULTS WhatIf: the exact Add/Remove it WOULD perform. -Commit: the membership changes applied, then a re-print of the group's membership. Verify the exact role-group name in your tenant first. .NOTES White-label — Purview Solutions. Default is a dry run; changes only with -Commit. No credentials. Uses Add-RoleGroupMember / Remove-RoleGroupMember / Get-RoleGroupMember (S&C PowerShell). Purview role naming evolves — confirm the role-group name (e.g. via CMMC-Discovery.ps1) before committing. > [CmdletBinding()] param([Parameter(Mandatory=$true)] [ValidateSet('Compliance Manager Administrators', 'Compliance Manager Assessors', 'Compliance Manager Contributors', 'Compliance Manager Readers')] [string]$RoleGroup, [string[]]$Add = @(), [string[]]$Remove = @(), [switch]$Commit, [string]$ExoConnectionUri) $WhatIf = -not $Commit $mode = $(if($WhatIf){'WHATIF (preview only)'}else{'COMMIT (applying changes)'})

CMMC-Validation.ps1

Purpose: Confirms whether the underlying Microsoft 365 technical controls that Compliance Manager can AUTOMATICALLY TEST for the CMMC (NIST SP 800-171) assessment are actually present, so you can tell which improvement actions can auto-pass and which still need MANUAL evidence. It maps each

checked signal to a NIST 800-171 family: unified audit logging (AU), Conditional Access / MFA (AC, IA), DLP + sensitivity-label + retention policies (MP, SC, media/records). It does NOT score CMMC and does NOT replace the portal or the C3PAO determination. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\CMMC-Validation.ps1 Sign in as a Compliance Administrator / Global Reader when prompted (S&C PowerShell + Graph). For GCC High pass -ExoConnectionUri / -GraphEnvironment as in CMMC-Discovery.ps1. EXPECTED RESULTS A family-by-family PASS/GAP table of the technical signals. "SIGNALS PRESENT" when the core automatable controls are found; any GAP is a candidate for manual evidence or a POA&M item. Read-only — makes no changes. Exit 0 if no gaps in the core signals, 1 otherwise. .NOTES White-label — Purview Solutions. Read-only. Uses Get-AdminAuditLogConfig / Get-DlpCompliancePolicy / Get-Label / Get-RetentionCompliancePolicy (S&C PowerShell) and Get-MgIdentityConditionalAccessPolicy (Graph). Signal presence is NOT a CMMC pass — evidence adequacy is a compliance/C3PAO determination. Verify per your tenant/cloud. > [CmdletBinding()] param([string]$ExoConnectionUri, [string]$GraphEnvironment = 'Global')

How to run: powershell -ExecutionPolicy Bypass -File .\CMMC-Validation.ps1 Sign in as a Compliance Administrator / Global Reader when prompted (S&C PowerShell + Graph). For GCC High pass -ExoConnectionUri / -GraphEnvironment as in CMMC-Discovery.ps1. EXPECTED RESULTS A family-by-family PASS/GAP table of the technical signals. "SIGNALS PRESENT" when the core automatable controls are found; any GAP is a candidate for manual evidence or a POA&M item. Read-only — makes no changes. Exit 0 if no gaps in the core signals, 1 otherwise. .NOTES White-label — Purview Solutions. Read-only. Uses Get-AdminAuditLogConfig / Get-DlpCompliancePolicy / Get-Label / Get-RetentionCompliancePolicy (S&C PowerShell) and Get-MgIdentityConditionalAccessPolicy (Graph). Signal presence is NOT a CMMC pass — evidence adequacy is a compliance/C3PAO determination. Verify per your tenant/cloud. > [CmdletBinding()] param([string]$ExoConnectionUri, [string]$GraphEnvironment = 'Global')